DATHEON / APPLICATION SECURITY

Task 2 — BOLA Remediation Report

Datheon Application Security & API Pentesting Internship · 30 October–27 November 2026

Adil Firoz · Batch 01 · The Neotia University · B.Tech Computer Science and Engineering (Cybersecurity)

LOCAL SYNTHETIC-DATA TRAINING PORTFOLIO

Task 2 — BOLA Remediation Report

Adil Firoz · Datheon Application Security & API Pentesting Internship · Batch 01

The Neotia University · B.Tech Computer Science and Engineering (Cybersecurity)

Assessment type: Local integration tests with synthetic data

Executive summary

The secure implementation derives the user's identity from a validated session and combines it with the requested record identifier in the server-side lookup. It returns 404 for both absent and non-owned records and omits the internal owner identifier from API output.

Objectives and scope

Validate unauthenticated denial, owner access, and cross-user access prevention in a localhost-only app. No external API or real personal information is used.

Architecture and tools

TypeScript/Node.js, Express, an in-memory SQLite database, HMAC-signed session cookies, and Vitest/Supertest integration tests.

Implementation and technical analysis

The ownership predicate is WHERE id = ? AND owner_id = ?; both values are bound parameters in a prepared SQLite statement. The identity comes from a signed and active session. The endpoint does not accept a client-supplied owner ID. A 404 response is used for absent and non-owned records; authentication failures return 401.

Test procedure and results

The regression test logs in as Alice, verifies her own record returns 200, verifies Bob's record returns 404, verifies a no-session request returns 401, and checks an SQL-looking identifier does not bypass the parameterized query. Actual run counts and pass/fail status appear in the generated PDF from reports/test-results.json.

Evidence

Automated test output is machine-generated from the run. No UI screenshots were captured; follow ../evidence/README.md for manual capture steps.

Remediation and conclusion

Enforce access control for every object on the server and bind the query to the validated principal. Preserve the test as a regression guard. The SQLite database is in-memory and resets on process restart; a deployed application must additionally manage durable storage and migrations.

References

- OWASP API Security Top 10 — API1: Broken Object Level Authorization.
- OWASP Cheat Sheet Series — Authorization Cheat Sheet.

Automated test execution

Vitest run: PASSED · 8/8 passed · 0 failed

Test case	RESULT	Duration
Task 1 and Task 2: object authorization rejects unauthenticated access and prevents cross-user record reads	PASSED	76 ms